

- Vulnerability assessment, where scanning and analysing of security risks are performed
- Penetration testing, where simulated malicious attackers attack the system and analyse it
- Runtime testing, where the end user performs security testing
- Code review, where the review and analysis of the system take place to find vulnerabilities

Open Web Application Security Project's (OWASP)

Zed Attack Proxy (ZAP) is a flexible, extensible and open source penetration testing tool, also known as a 'man-in-the-middle proxy'. ZAP can intercept and inspect messages sent between a browser and the web application, and perform other operations as well. It is designed to help developers and security professionals identify vulnerabilities in web applications and web services. It can find common web application security issues such as cross-site scripting (XSS), SQL injection, and cross-site request forgery (CSRF). OWASP ZAP also supports plugins that can be used to extend its functionality. Its ease of use, a large user base, user-friendly interface and configurability help to meet the specific needs of projects in business units. Given below is a brief description of this tool.

|                                                    |                                                                                                                                                                                                                                     |
|----------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Initial release                                    | 2014                                                                                                                                                                                                                                |
| Stable release                                     | 2.12.0                                                                                                                                                                                                                              |
| Written in                                         | Java                                                                                                                                                                                                                                |
| License                                            | Apache License 2.0                                                                                                                                                                                                                  |
| Website                                            | <a href="https://owasp.org/www-project-zap/">https://owasp.org/www-project-zap/</a>                                                                                                                                                 |
| GitHub repository                                  | <a href="https://github.com/zaproxy/zaproxy">https://github.com/zaproxy/zaproxy</a>                                                                                                                                                 |
| Features                                           | <ul style="list-style-type: none"> <li>• Intercepting proxy</li> <li>• Active and passive scanners</li> <li>• Traditional and ajax spiders</li> <li>• Brute force scanner</li> <li>• Port scanner</li> <li>• Web sockets</li> </ul> |
| Risk categories                                    | <ul style="list-style-type: none"> <li>• High</li> <li>• Medium</li> <li>• Low</li> <li>• Informational</li> <li>• False positive</li> </ul>                                                                                        |
| How is it useful in implementing DevOps practices? | Penetration testing                                                                                                                                                                                                                 |
| Can we integrate it with Pipeline as Code?         | Yes                                                                                                                                                                                                                                 |

|                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Is a commercial flavour available? | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| ZAP Docker image scan              | <p>Docker stable image can be obtained using <i>docker pull owasp/zap2docker-stable</i>:</p> <ol style="list-style-type: none"> <li>1. <i>ZAP - Baseline scan</i>: This executes the ZAP spider against the specified target for one minute and then completes the passive scanning.</li> </ol> <p><b>zap-baseline.py -t &lt;target&gt; [options]</b></p> <ol style="list-style-type: none"> <li>1. <i>ZAP - Full scan</i>: This executes ZAP spider against the specified target, an optional ajax spider scan and then a full active scan.</li> </ol> <p><b>zap-full-scan.py -t &lt;target&gt; [options]</b></p> <ol style="list-style-type: none"> <li>1. <i>ZAP - API scan</i>: This is suitable to perform scans against APIs defined by OpenAPI, SOAP, or GraphQL.</li> </ol> <p><b>zap-api-scan.py -t &lt;target&gt; -f &lt;format&gt; [options]</b></p> |

OWASP ZAP offers several benefits for web application security testing:

- It is an open source tool.
- It has a user-friendly interface that makes it easy to perform security testing on web applications and microservices.
- It covers a range of scanning capabilities such as active scanning, passive scanning, and spidering.
- OWASP ZAP can be integrated into continuous integration and continuous delivery (CI/CD) pipelines.
- It has an active community of users and contributors for continuous improvement and innovation.

OWASP ZAP Desktop is a graphical user interface (GUI) for the OWASP ZAP security testing tool. It provides an easy-to-use and user-friendly interface for executing security tests on web applications and microservices.

The ZAP Desktop provides many of the same features and functionality as the command-line version of OWASP ZAP such as the ability to perform automated and manual security tests. Additionally, it offers visual representation of the test results and an easy-to-use interface.